

SkillUp

In collaboration with
IBM SkillsBuild



SkillUp Online In collaboration with IBM SkillsBuild Presents

10 Semanas Certificado Profesional en Ciberseguridad | 1Q 2026



Agenda de la 2da sesión técnica

COMPRENDER LAS AMENAZAS

- Introducción a las fuentes de inteligencia de amenazas
- Interpretación de informes de escaneo y priorización de correcciones
- Descripción general de las 10 principales vulnerabilidades de OWASP
- Práctica: Ejecución de escaneos de vulnerabilidades utilizando OpenVAS/Nessus



01

Comprender las Vulnerabilidades

Conceptos clave · Amenazas · Vulnerabilidades

SkillUp

In collaboration with
IBM SkillsBuild

Amenazas y vulnerabilidades

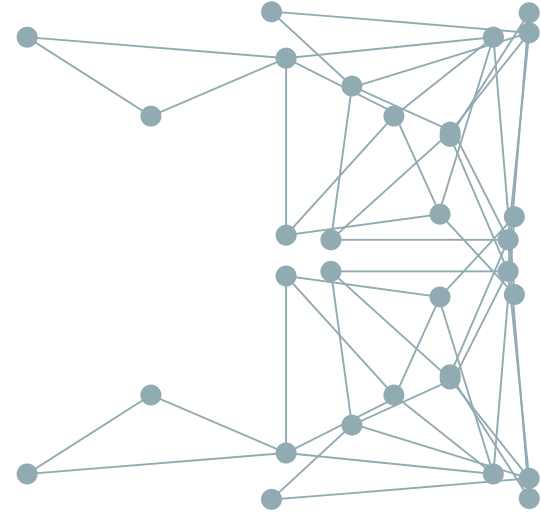
VULNERABILIDADES

Debilidad en el hardware/firmware/software que un hacker puede explotar.

EJEMPLO: Imagina que usas un móvil obsoleto para el que el fabricante ya no ofrece actualizaciones/firmware.

AMENAZAS FÍSICAS

Es una amenaza directa a los activos, como la intrusión no autorizada en un área restringida y los peligros naturales, como los incendios, vandalismo o que dañan los centros de datos, desactivan la energía o interrumpen los dispositivos de red. También pueden ser robo de datos o robar una computadora portátil o una unidad de disco duro.



Tipos de amenazas

AMENAZAS INTERNAS

Algunas amenazas físicas son internas. Por ejemplo, un trabajador malintencionado podría abusar de su acceso autorizado a un centro de datos para robar una de sus unidades de disco duro. A su vez, pueden vender los datos de esa unidad al mejor postor.

AMENAZAS EXTERNAS

Un atacante podría usar tácticas físicas de ingeniería social, como tailgating, para ingresar a un área restringida sin que nadie lo note. Cuando está dentro, puede robar portátiles o dispositivos. O puede conectar una unidad flash USB a una estación de trabajo y luego instalar un virus desde esa unidad. Ese virus puede propagarse por la red.



Amenazas y vulnerabilidades

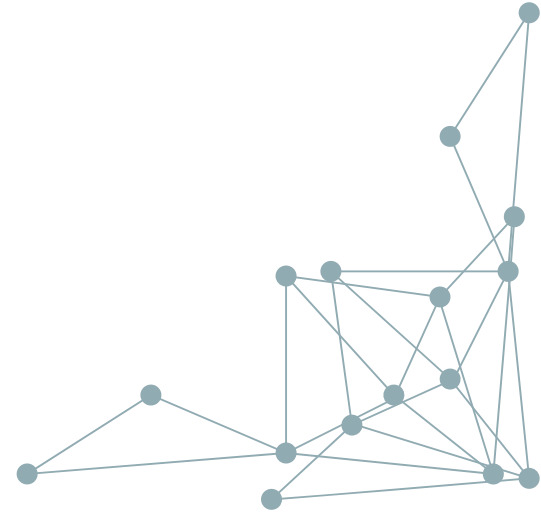
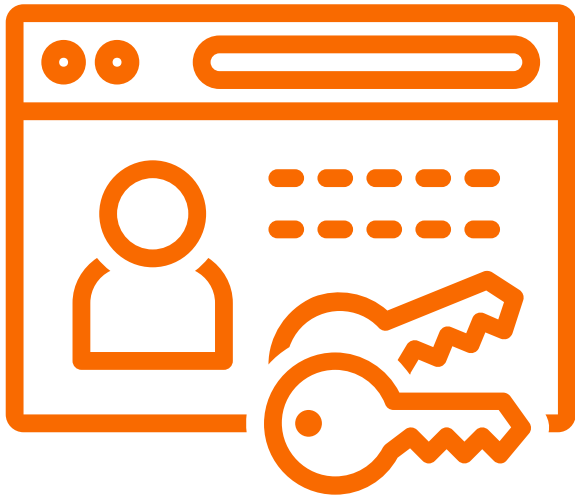
DEFENSA EN PROFUNDIDAD

Estrategia en la que usas múltiples capas de controles de seguridad para proteger los activos.

Los controles suelen ser redundantes, pero eso es predeterminado. Si uno falla, otro compensa. Esa es la filosofía detrás de la defensa en profundidad.

Las capas suelen incluir 3 tipos de controles:

- **Técnicos**
- **Administrativos**
- **Físicos**

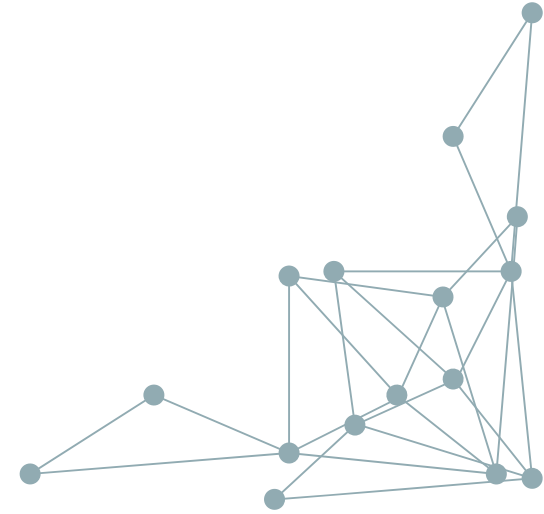
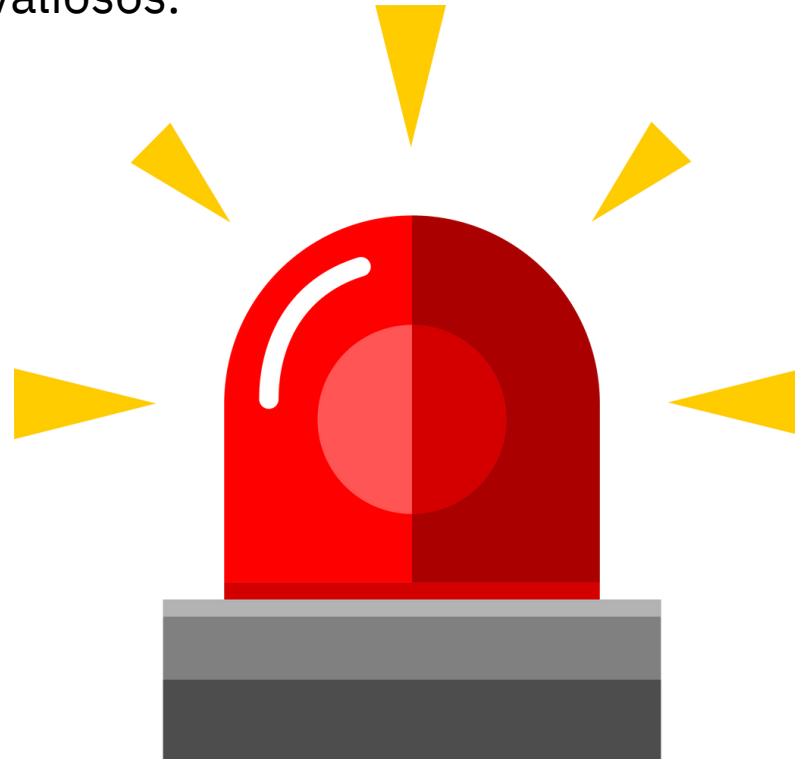


Amenazas y vulnerabilidades

Los ataques de ciberseguridad suelen incluir elementos digitales, como el malware, y psicológicos, como el phishing. Pero ningún programa de ciberseguridad está completo sin tener en cuenta las **amenazas físicas** a los edificios y dispositivos que albergan activos valiosos.

CONTROLES FÍSICOS

Alarmas, cercas y cámaras de seguridad. Es posible que incluso los hayas usado para protegerte a ti o tus pertenencias

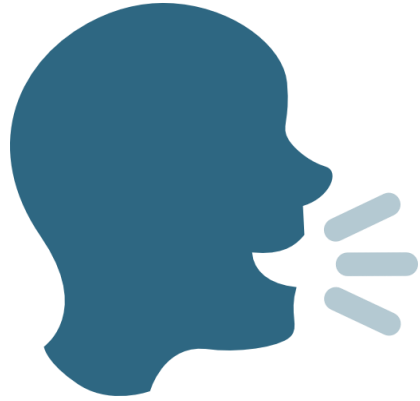


Amenazas y vulnerabilidades

Los tipos y la cantidad de controles físicos dependen de la organización y los activos que se deben proteger. En general, los controles físicos pueden servir para **5 propósitos**



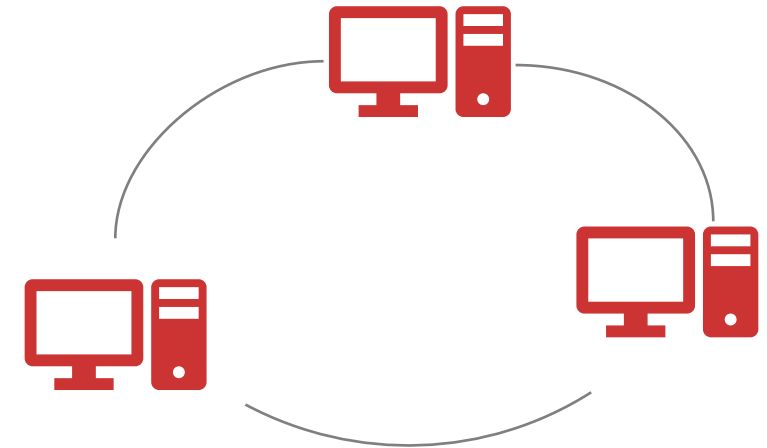
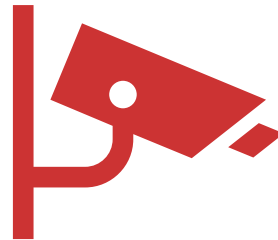
Seguridad de la información



- Formato electrónico
- Formato verbal
- Mensajes escritos
- Mensajes impresos



Seguridad informática



Seguridad de la información VS. Ciberseguridad



Comprender los Fundamentos de la Ciberseguridad

CIBERSEGURIDAD

Práctica de proteger y recuperar datos, redes, dispositivos y programas de ciberataques maliciosos.

AMENAZA

Todo aquello que pueda provocar que algo perjudicial suceda en tu red, sistema o datos.



VULNERABILIDADES

Debilidades en hardware/software que un hacker puede explotar.



ATACANTES

Personas que intentan eludir la seguridad del sistema para acceder a datos.



MALWARE

Software diseñado para amenazar la confidencialidad, integridad o disponibilidad.

Comprender los Fundamentos

VULNERABILIDADES

Debilidad en el hardware/firmware/software que un hacker puede explotar.

EJEMPLO: Imagina que usas un móvil obsoleto para el que el fabricante ya no ofrece actualizaciones.

Los atacantes emplean estos fallos para acceder a computadores, redes y datos confidenciales.



Vulnerabilidades



Las debilidades del sistema...



SkillUp

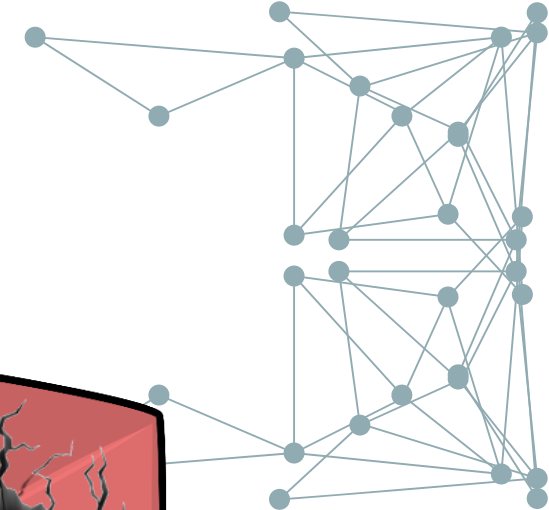
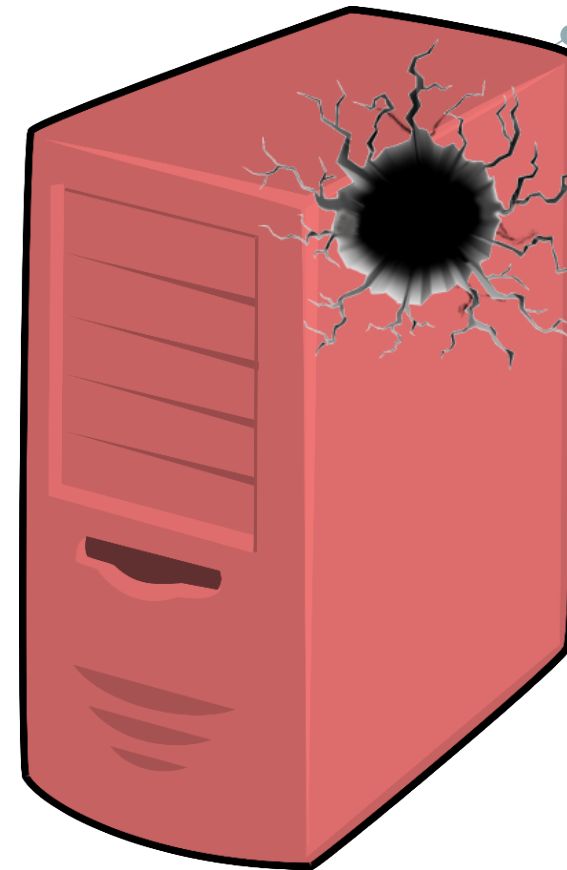
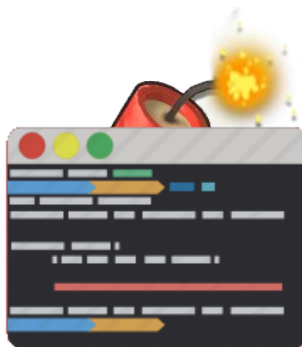


In collaboration with
IBM SkillsBuild

Vulnerabilidades



Las debilidades del sistema...



SkillUp

In collaboration with
IBM SkillsBuild



02

Inteligencia de Amenazas

Cyber Threat Intelligence (CTI)

SkillUp

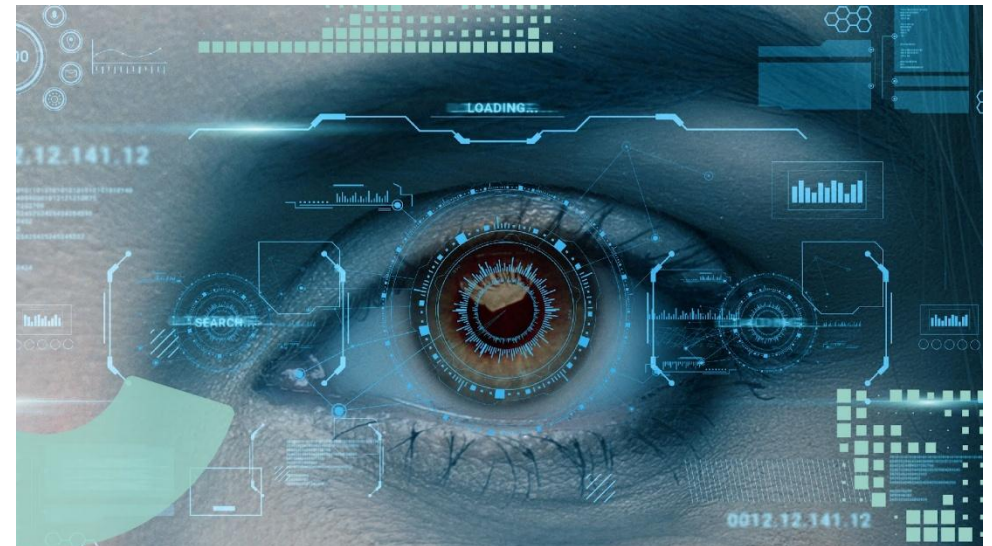
In collaboration with
IBM SkillsBuild

GESTIÓN DE VULNERABILIDADES

QUÉ ES LA INTELIGENCIA DE AMENAZAS

La inteligencia de amenazas es inteligencia que ayuda a las organizaciones a tomar decisiones informadas sobre las amenazas de ciberseguridad.

- Recopilar datos de amenazas de varias fuentes
- Examinar esos datos
- Descubrir patrones o tendencias
- Obtener conclusiones significativas sobre las amenazas



QUÉ ES LA INTELIGENCIA DE AMENAZAS

Cuando se habla de inteligencia de amenazas, los profesionales de la ciberseguridad suelen emplear el término actor de amenazas en lugar de atacante.

Un atacante/ciberatacante: alguien que intenta burlar la seguridad del sistema o de la red sin autorización con fines maliciosos.

Un actor de amenazas/actor malicioso: entidad (persona, grupo u organización) que supone una amenaza para la ciberseguridad. Puede no intentar atacar todavía, pero planea hacerlo.

- Aunque los términos "atacante" y "actor de amenazas" tienen significados similares, el de actor de amenazas hace hincapié en la amenaza potencial que supone la entidad.

Tipos de Inteligencia de Amenazas



ESTRATÉGICA



CISO · Directivos · Junta

Visión de alto nivel sobre el panorama de amenazas. Informa decisiones de negocio y gestión de riesgos a largo plazo.

- ▶ Tendencias geopolíticas y cibernéticas
- ▶ Análisis de motivaciones de actores
- ▶ Impacto en la estrategia empresarial
- ▶ Informes ejecutivos y dashboards



Largo plazo (meses – años)



OPERATIVA



SOC Managers · Threat Hunters

Información sobre campañas, actores y sus capacidades actuales. Soporta la planificación defensiva y la caza de amenazas.

- ▶ Campañas activas identificadas
- ▶ TTPs de actores específicos
- ▶ Infraestructura de C2
- ▶ Alertas tempranas de campañas



Medio plazo (semanas – meses)



TÁCTICA



Analistas SOC · IR Teams

IOCs y artefactos técnicos para detección y bloqueo inmediato. Altamente consumible por herramientas automáticas.

- ▶ IPs, dominios y hashes maliciosos
- ▶ Reglas YARA y Sigma
- ▶ Firmas IDS/IPS
- ▶ Feeds de threat intelligence



Corto plazo (horas – días)



Qualquiera puede

ies de noticias,

In collaboration with
IBM SkillsBuild

Fuentes de Inteligencia de amenazas

[Agencia de Seguridad de Infraestructura y Ciberseguridad](#): el sitio web de la Agencia de Seguridad de Infraestructura y Ciberseguridad (CISA) es útil para descubrir amenazas actuales y denunciar problemas de ciberseguridad que experimente.

[IBM X-Force Exchange](#): IBM X-Force Exchange es una plataforma basada en la nube para descubrir las últimas amenazas, revisar reportes de inteligencia y colaborar con otros profesionales de ciberseguridad.

[Yeti](#): Yeti es un repositorio integral de datos de amenazas, incluidos IoC, presentados a través de interfaces de usuario fáciles de usar para humanos y máquinas.

[InfraGard](#): InfraGard es un programa de inteligencia de amenazas basado en membresía de la Oficina Federal de Investigaciones (FBI) que ofrece noticias, capacitación y orientación experta a organizaciones privadas.

Fuentes de inteligencia de amenazas

CVSS
5.3

X-Force Vulnerability Report

KNIME Business Hub information disclosure

CVE-2023-2541

This report does not contain tags. Add tags via the comment box.

Details

knime-cve20232541-info-disc (257431) reported Jun 7, 2023

KNIME Business Hub could allow a remote attacker to obtain sensitive information, caused by improper access control. By sending a specially crafted request, an attacker could exploit this vulnerability to obtain versions, host names, or IP addresses information, and use this information to launch further attacks against the affected system.

Consequences:

Obtain Information

Remedy

Refer to KNIME Security Advisory for patch, upgrade or suggested workaround information. See References.

CVSS 3.0 Base Score

5.3

Attack Vector	Network
Attack Complexity	Low
Privileges Required	None
User Interaction	None
Scope	Unchanged
Confidentiality Impact	Low
Integrity Impact	None
Availability Impact	None

CVSS 3.0 Temporal Score

4.6

Exploitability	Unproven
Remediation Level	Official Fix
Report Confidence	Confirmed

knime-cve20232541-info-disc (257431) Según se informó el 7 de junio de 2023, KNIME Business Hub podría permitir a un atacante remoto obtener información confidencial, debido a un control de acceso inadecuado. Enviando una solicitud especialmente diseñada, un atacante podría aprovechar esta vulnerabilidad para obtener información sobre versiones, nombres de host o direcciones IP, y emplear esta información para lanzar nuevos ataques contra el sistema afectado.

Consecuencias: Obtención de información

Solución: Consulta el aviso de seguridad de KNIME para obtener información sobre parches, actualizaciones o soluciones sugeridas. Ver referencias.

SkillUp

In collaboration with
IBM SkillsBuild

EXPRESIÓN ESTRUCTURADA DE INFORMACIÓN SOBRE AMENAZAS

Una de las mejores herramientas para organizar la inteligencia sobre amenazas es Structured Threat Information Expression (STIX). STIX es lenguaje estandarizado que utiliza un léxico basado en JSON, que proporciona un formato estandarizado para compartir inteligencia sobre amenazas.

El lenguaje trata cada información como un bloque de código llamado objeto.

- Cada objeto tiene una propiedad llamada **tipo** que indica el concepto de inteligencia sobre amenazas relevante para el objeto, como "patrón de ataque", "actor de la amenaza" o "ubicación".
- Otras propiedades representan características como el **nombre** y la **descripción** del objeto. Por ejemplo, el tipo de un objeto puede ser "patrón de ataque", y su **nombre** puede ser "spear phishing".

Tipos de Objetos STIX Comunes



Patrón de ataque



Campaña



Curso de acción



Identidad



Indicador



Ubicación



Malware



Actor de amenazas



Herramienta

Patrón de ataque

“Un tipo de TTP [tácticas, técnicas y procedimientos] que describe las formas en que los adversarios intentan comprometer sus objetivos”

Identidad

Individuos, organizaciones o grupos específicos que fueron atacados, como el sector financiero

Malware

Un tipo de TTP que representa código malicioso

Campaña

“Un grupo de comportamientos adversarios que describe un conjunto de actividades maliciosas o ataques (a veces llamados oleadas) que ocurren durante

Indicador “Contiene un patrón que se puede usar para detectar ciberactividad sospechosa o maliciosa”

Actor de amenazas

“Individuos, grupos u organizaciones reales que se cree que operan con intenciones maliciosas”

Curso de acción

“Una recomendación de un productor de inteligencia a un consumidor sobre las acciones que podría tomar en respuesta a esa inteligencia”

Ubicación

“Representa una ubicación geográfica”

Herramienta

“Software que pueden emplear los actores de amenazas para realizar ataques”

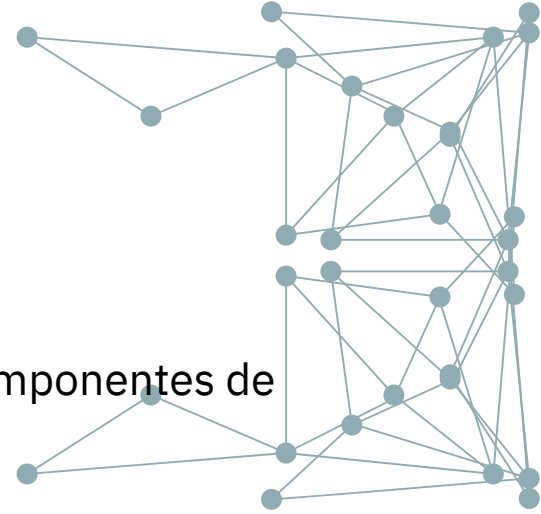
Expresiones STIX

¿**Cómo usar expresiones STIX?** En programación, una expresión es una combinación de componentes de código que un programa puede interpretar y usar.

Cada objeto STIX es una expresión que consta del tipo y las propiedades del objeto.

Las expresiones STIX vienen en **JavaScript Object Notation (JSON)**, un formato de datos estándar basado en texto.

JSON emplea texto legible por humanos que puede almacenar y transmitir fácilmente mediante un sistema automatizado.





Expresiones STIX

```
{  
  
  "tipo": "indicador",  
  
  "id": "indicador-2f54e292-8b64-4495-bc02-6a9198a365e3",  
  
  "creado": "2022-02-01T 08:08:15.000 Z",  
  
  "modificado": "2023-02-15T 08:08:15.000 Z",  
  
  "patrón": "[Archivo: hashes.md5 = 'd41d8cd98f00b204e9800998ecf8427e']",  
  
  "valid_from": "2022-03-15T 08:08:15.000 Z",  
  
  "etiquetas": ["malware"],  
  
  "nombre": "Archivo vacío MD5 hash",  
  
  "description": "Indica la presencia de un archivo vacío con un valor hash MD5 de  
d41d8cd98f00b204e9800998ecf8427e, que es una táctica común utilizada por los autores  
de malware para evadir la detección".  
}
```

tipo

La propiedad **type** especifica el tipo del objeto STIX, como *relación*, *vulnerabilidad*, *indicador* o *patrón de ataque*.

En este ejemplo, el tipo es un indicador, que es un patrón asociado a una actividad maliciosa conocida.

creado

La propiedad **created** es una marca de tiempo que indica cuándo se creó el objeto.

En este ejemplo, la hora es el 1 de febrero de 2022 a las 8:08 a. m.

Expresiones STIX

```
{  
  
  "tipo": "indicador",  
  
  "id": "indicador-2f54e292-8b64-4495-bc02-6a9198a365e3",  
  
  "creado": "2022-02-01T 08:08:15.000 Z",  
  
  "modificado": "2023-02-15T 08:08:15.000 Z",  
  
  "patrón": "[Archivo: hashes.md5 = 'd41d8cd98f00b204e9800998ecf8427e']",  
  
  "valid_from": "2022-03-15T 08:08:15.000 Z",  
  
  "etiquetas": ["malware"],  
  
  "nombre": "Archivo vacío MD5 hash",  
  
  "description": "Indica la presencia de un archivo vacío con un valor hash MD5 de  
d41d8cd98f00b204e9800998ecf8427e, que es una táctica común utilizada por los autores  
de malware para evadir la detección".  
}
```

modificado

La propiedad **modificada** es una marca de tiempo que indica cuándo se modificó el objeto por última vez.

En este ejemplo, la última modificación ocurrió el 15 de febrero de 2023, a las 8:08 a. m.

patrón

La propiedad del **patrón** identifica un patrón de detección.

En este ejemplo, el patrón es un hash identificable.

Expresiones STIX

```
{  
  
  "tipo": "indicador",  
  
  "id": "indicador-2f54e292-8b64-4495-bc02-6a9198a365e3",  
  
  "creado": "2022-02-01T 08:08:15.000 Z",  
  
  "modificado": "2023-02-15T 08:08:15.000 Z",  
  
  "patrón": "[Archivo: hashes.md5 = 'd41d8cd98f00b204e9800998ecf8427e']",  
  
  "valid_from": "2022-03-15T 08:08:15.000 Z",  
  
  "etiquetas": ["malware"],  
  
  "nombre": "Archivo vacío MD5 hash",  
  
  "description": "Indica la presencia de un archivo vacío con un valor hash MD5 de  
d41d8cd98f00b204e9800998ecf8427e, que es una táctica común utilizada por los autores  
de malware para evadir la detección".  
}
```

valid_from

La propiedad **valid_from** es específica de los objetos indicadores.

Especifica cuándo se consideró por primera vez que el indicador era un patrón válido para asociarlo a una actividad maliciosa.

En este ejemplo, la fecha `valid_from` es el 15 de marzo de 2022 a las 8:08 a. m.

etiquetas

La propiedad de las **etiquetas** indica uno o más términos preestablecidos para describir el objeto.

Este ejemplo incluye solo una etiqueta: *malware*.

Expresiones STIX

```
{  
  
  "tipo": "indicador",  
  
  "id": "indicador-2f54e292-8b64-4495-bc02-6a9198a365e3",  
  
  "creado": "2022-02-01T 08:08:15.000 Z",  
  
  "modificado": "2023-02-15T 08:08:15.000 Z",  
  
  "patrón": "[Archivo: hashes.md5 = 'd41d8cd98f00b204e9800998ecf8427e']",  
  
  "valid_from": "2022-03-15T 08:08:15.000 Z",  
  
  "etiquetas": ["malware"],  
  
  "nombre": "Archivo vacío MD5 hash",  
  
  "description": "Indica la presencia de un archivo vacío con un valor hash MD5 de  
d41d8cd98f00b204e9800998ecf8427e, que es una táctica común utilizada por los autores  
de malware para evadir la detección".  
}
```

descripción

La propiedad **description** describe el objeto en lenguaje natural, no en código.

En este ejemplo, la descripción indica que la amenaza aparece como un archivo vacío con el valor hash MD5 proporcionado, una táctica común para evadir la detección.

Práctica de STIX

```
{  
  
  "type": "malware",  
  
  "id": "malware--8cbf14e9-2ba2-44fe-9e12-fccb8d2419c2",  
  
  "created": "2022-01-07T07:07:17.000Z",  
  
  "modified": "2022-03-15T001:08:15.000Z",  
  
  "valid_from": "2022-01-01T07:07:14.000Z",  
  
  "malware_types": ["ransomware"],  
  
  "name": "CryptolockerX",  
  
  "description": "A variant of cryptolocker.",  
  
  "threat_actor": "unknown"  
  
}
```

1. ¿Cuál es el tipo de este objeto?
2. ¿Qué tipo de malware está asociado con este objeto?
3. ¿Cuál es el nombre del objeto?
4. ¿Cuándo se confirmó por primera vez que el indicador era un patrón asociado con actividad maliciosa? Indica solo el mes, la fecha y el año, y usa el siguiente formato: Año-Mes-Día. Por ejemplo, si la confirmación se produjo el 1 de mayo de 2023, escribirías "2023-05-01" sin comillas.

Expresiones STIX

```
{  
  "type": "malware",  
  "id": "malware--8cbf14e9-2ba2-44fe-9e12-fccb8d2419c2",  
  "created": "2022-01-07007:07:17.000Z",  
  "modified": "2022-03-15T001:08:15.000Z",  
  "valid_from": "2022-01-01T07:07:14.000Z",  
  "malware_types": ["ransomware"],  
  "name": "CryptolockerX",  
  "description": "A variant of cryptolocker.",  
  "threat actor": "unknown"  
}
```

1. ¿Cuál es el tipo de este objeto? **malware** ✓
2. ¿Qué tipo de malware está asociado con este objeto? **ransomware** ✓
3. ¿Cuál es el nombre del objeto? **CryptolockerX** ✓
4. ¿Cuándo se confirmó por primera vez que el indicador era un patrón asociado con actividad maliciosa? Indica solo el mes, la fecha y el año, y usa el siguiente formato: Año-Mes-Día. Por ejemplo, si la confirmación se produjo el 1 de mayo de 2023, escribirías "2023-05-01" sin comillas.
2022-01-01 ✓



04

Gestión de Vulnerabilidades

Prevenir vulnerabilidades a escala

SkillUp

In collaboration with
IBM SkillsBuild

¿Qué es una evaluación de vulnerabilidad?

Las evaluaciones de vulnerabilidad incluyen 4 pasos:

01

IDENTIFICACIÓN

Escaneo de sistemas y redes para detectar debilidades.

02

ANÁLISIS

Evaluación del impacto potencial de cada vulnerabilidad.

03

PRIORIZACIÓN

Clasificación según riesgo mediante puntaje o ranking.

04

CORRECCIÓN

Aplicación de parches, controles y medidas correctivas.



Importancia de la fase de priorización

PRIORIZACIÓN

Las vulnerabilidades se priorizan manualmente o con software de gestión. Se califican mediante un sistema de puntaje o clasificación.



Ejemplo: IBM® X-Force Red

Ayuda a las organizaciones a clasificar las vulnerabilidades e implementar controles de forma rápida y sencilla.

EU
RGPD

Reglamento General de
Protección de Datos



PCI DSS

Payment Card Industry Data
Security Standard

Trayectoria Profesional – Analista de Vulnerabilidades



ANALISTA DE VULNERABILIDADES

Si te interesa la evaluación de vulnerabilidades, puedes comenzar como analista de vulnerabilidades.



Evaluar los sistemas y redes de una organización



Medir la efectividad de los controles de seguridad contra vulnerabilidades conocidas

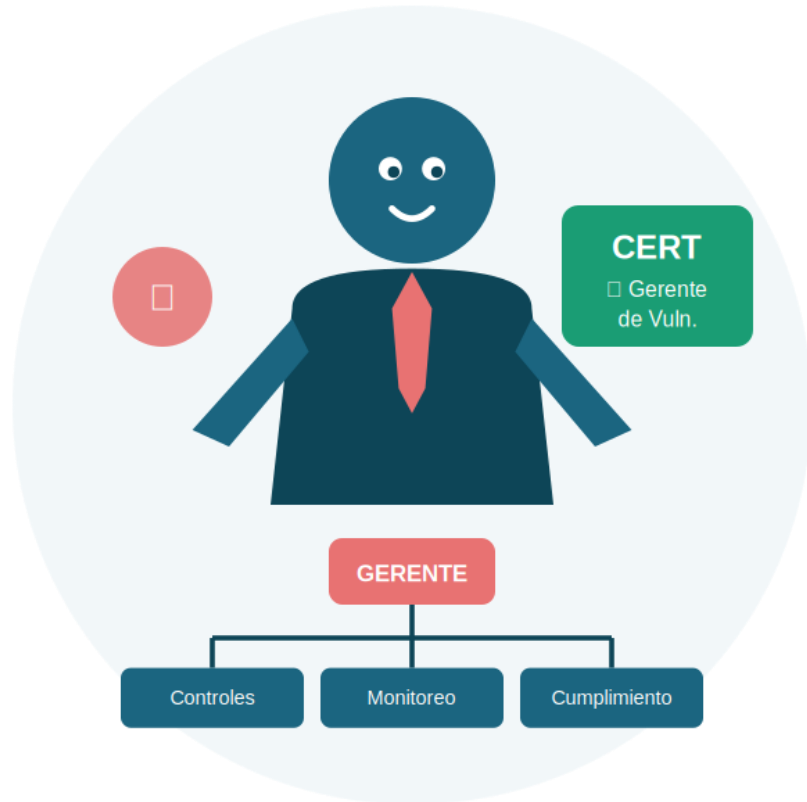


Conocer la inteligencia de amenazas más reciente para su organización



Ser hábil en el uso de las mejores herramientas de evaluación de vulnerabilidades

Trayectoria profesional - gerente de vulnerabilidades



GERENTE DE VULNERABILIDADES

El gerente conoce las tareas de los analistas, y además gestiona el programa completo de amenazas.



Monitorear el ciclo de vida general de un programa de gestión de amenazas



Identificar brechas en los controles administrativos, físicos y técnicos



Diseñar y recomendar cambios de seguridad según sea necesario



Presentar necesidades de seguridad a la dirección y mantener cumplimiento normativo



04

Pruebas de Penetración

Pentesting VS. Hacking

SkillUp

In collaboration with
IBM SkillsBuild

¿Qué son las pruebas de penetración?

Son un tipo de pruebas de seguridad que **simulan técnicas reales** de hackeo para encontrar vulnerabilidades de aplicaciones, redes o sistemas que los atacantes pueden explotar.

Los escáneres de vulnerabilidades ayudan a identificar vulnerabilidades.

Estos escaneos son rápidos y no invasivos, por lo que puedes realizarlos de manera regular para encontrar vulnerabilidades comunes.



Hacking Ético

Un evaluador de pruebas de penetración es un tipo de hacker ético.

HÁCKER
ÉTICO



EVALUADOR DE
PRUEBAS DE
PENETRACIÓN



Hacking Ético



EVALUADOR DE
PRUEBAS DE
PENETRACIÓN

Los hackers éticos emplean varios métodos, como el análisis de malware y la evaluación de riesgos.

Las pruebas de penetración son solo una de las muchas herramientas que un hacker ético podría usar.

Todos los evaluadores son hackers éticos, pero no todos los hackers éticos son evaluadores.

Fases de las pruebas de penetración

La mayoría de los modelos de prueba de penetración incluyen las tareas básicas y el proceso general que se encuentran en el siguiente modelo. Pueden ser 4 fases



Herramientas de Pruebas de Penetración

Herramientas para la recopilación de información



MAPEADORES DE RED

Encuentran y mapean todos los dispositivos en una red.
EJ: direccion IP

ESCÁNERES DE PUERTOS

- Identifican los puertos abiertos o disponibles de una red.
- Puerto abierto es aquel que acepta una conexión
- Un puerto es un punto de conexión de red que envía o recibe datos para un servicio específico, como el correo electrónico.

ESCÁNERES DE VULNERABILIDADES

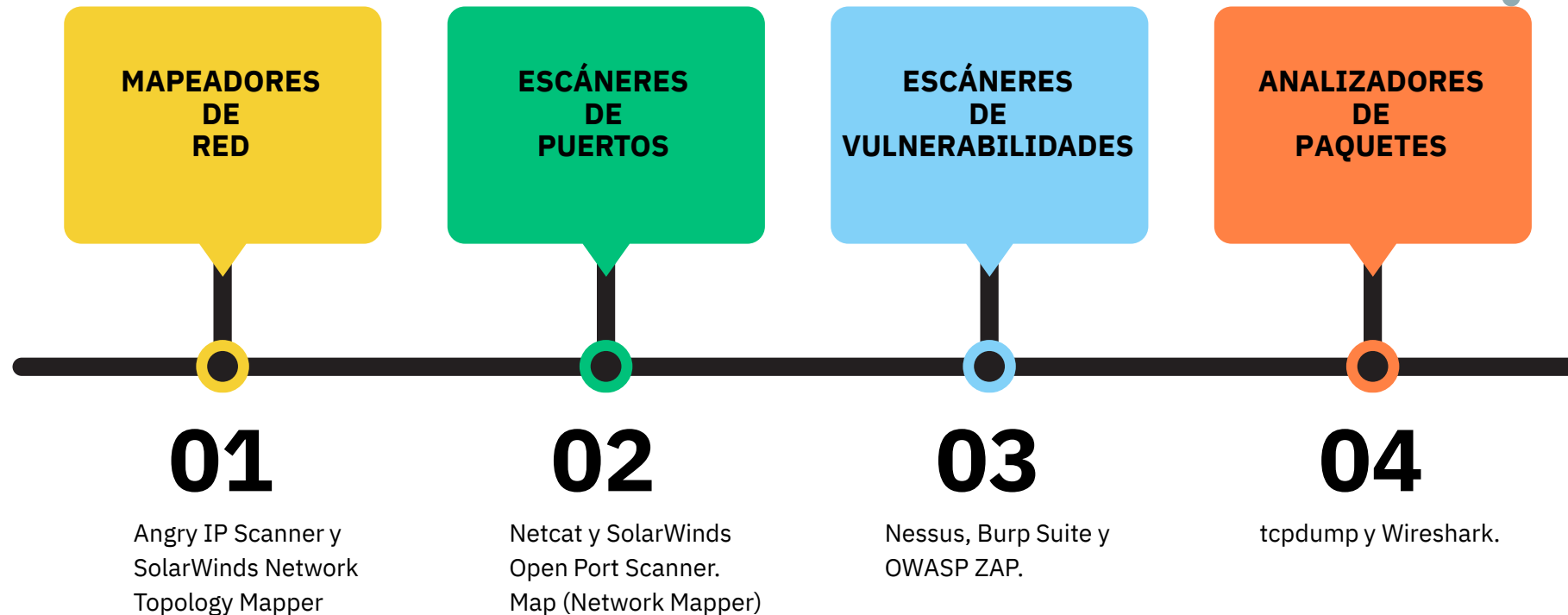
Analizan un sistema en busca de vulnerabilidades conocidas (software obsoleto, parches faltantes, configuraciones erróneas o contraseñas débiles)

ANALIZADORES DE PAQUETES

- Capturan e inspeccionan datos en tránsito a través de una red.
- Se puede determinar la cantidad de tráfico, la frecuencia de transmisión e incluso el contenido de los datos

Herramientas de Pruebas de Penetración

Herramientas para la recopilación de información



Herramientas de Ataque más comunes

Los marcos de explotación proporcionan repositorios de ataques y exploits prediseñados.

El proyecto ***Metasploit***, una herramienta para encontrar exploits existentes o compartir los propios.

Con la aplicación Metasploit, puedes automatizar una variedad de ataques según la arquitectura del objetivo.

Ejemplo: buscar ataques adaptados a una versión específica de un sistema operativo y luego dejar que Metasploit realice el ataque.



Herramientas de ataque más comunes



Las herramientas de descifrado de contraseñas ayudan a descubrir contraseñas anulando el cifrado o realizando ataques de fuerza bruta.

Un ataque de fuerza bruta es cuando el atacante emplea prueba y error, probando diferentes contraseñas hasta que encuentra una que funcione.

Herramienta más conocidas para descifrar contraseñas es **John the Ripper**.



05

Metodología OWASP

OWASP Top 10

SkillUp

In collaboration with
IBM SkillsBuild

¿Qué es OWASP?



<https://owasp.org>

OWASP son las siglas de Open Worldwide Application Security Project (Proyecto Abierto de Seguridad en Aplicaciones a Nivel Mundial)

Organización sin ánimo de lucro que se dedica a mejorar la seguridad del software

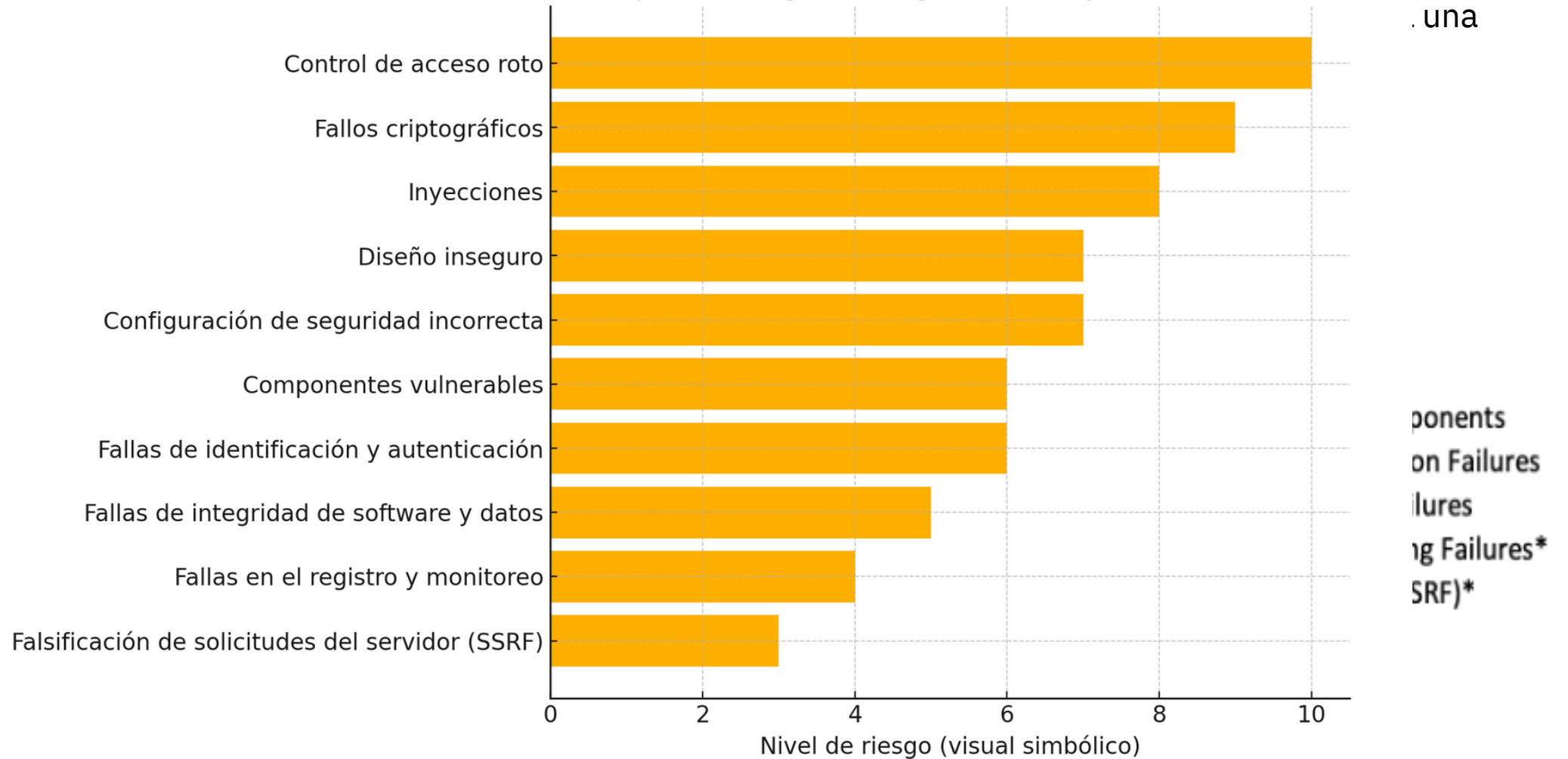
Objetivo: ayudar a desarrolladores, empresas y usuarios a crear aplicaciones más seguras, proporcionando recursos gratuitos y abiertos.

Top 10 OWASP

La última actualización

A01:20
A02:20
A03:20
A04:20
A05:20
A06:20
A07:20
A08:20
A09:20
A10:20

OWASP Top 10 – Riesgos de Seguridad en Aplicaciones Web (2021)



SkillUp

In collaboration with
IBM SkillsBuild

OWASP TOP 10

Las 10 principales amenazas de seguridad en aplicaciones web



El OWASP Top 10 es un estándar reconocido que ayuda a las organizaciones a identificar y priorizar los riesgos de seguridad en aplicaciones web.

1

A01:2021 – Fallos de control de acceso



Ocorre cuando las restricciones sobre lo que los usuarios autenticados pueden hacer no se aplican correctamente.

Ejemplo: Un usuario accede a funciones o datos que no debería.

2

A02:2021 – Fallos criptográficos



Fallas relacionadas con la protección inadecuada de datos sensibles.

Ejemplo: Datos sensibles transmitidos sin cifrado.

3

A03:2021 – Inyección

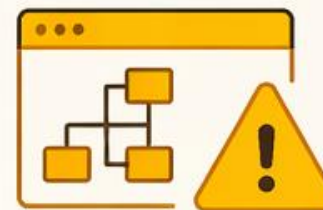


Ocorre cuando datos no confiables se envían a un intérprete como parte de un comando o consulta.

Ejemplo: SQL Injection, NoSQL Injection, OS Command Injection.

4

A04:2021 – Diseño inseguro



Fallas debido a un diseño de aplicación que no considera la seguridad desde el inicio.

Ejemplo: Flujos de negocio inseguros, falta de validaciones.

5

A05:2021 – Configuración incorrecta de seguridad



Configuraciones incorrectas que exponen la aplicación y sus componentes.

Ejemplo: Directorios expuestos, mensajes de error detallados.

6

A06:2021 – Componentes vulnerables y desactualizados



Uso de componentes con vulnerabilidades conocidas.

7

A07:2021 – Fallos de identificación y autenticación



Fallas en los mecanismos de inicio de sesión y gestión de sesiones.

8

A08:2021 – Fallos en la integridad del software y datos



Ocorre cuando código, actualizaciones o datos no están protegidos de manipulación.

9

A09:2021 – Fallos en el registro y monitoreo de seguridad



No registrar, monitorear o responder adecuadamente a eventos de seguridad.

10

A10:2021 – Falsificación de solicitudes del lado del servidor (SSRF)



La aplicación hace solicitudes a recursos internos o externos sin la validación adecuada.



06

PRÁCTICA: EJECUCIÓN DE ESCANEOS DE VULNERABILIDADES

OPENVAS/NESSUS



Greenbone OpenVAS

Open Vulnerability Assessment Scanner

Greenbone OpenVAS

OpenVAS is a full-featured vulnerability scanner. Its capabilities include unauthenticated and authenticated testing, various high-level and low-level internet and industrial protocols, performance tuning for large-scale scans and a powerful internal programming language to implement any type of vulnerability test.

The scanner obtains the tests for detecting vulnerabilities from a [feed](#) that has a long history and daily updates.

OpenVAS has been developed and driven forward by the company [Greenbone](#) since 2006. As part of the commercial vulnerability management product family Greenbone Enterprise Appliance, the scanner forms the [Greenbone Community Edition](#) together with other open-source modules.

Read more about the history of OpenVAS [here](#).

Related Links



Products



Test Now



**Product
Documentation**



**Security Response
Team**



Source Code



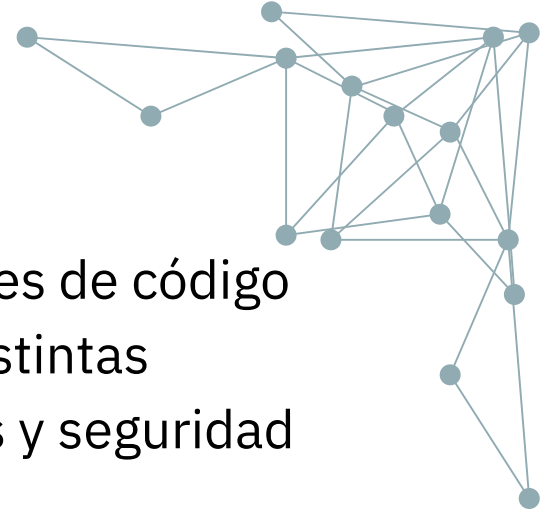
Community Forum

<https://www.openvas.org>

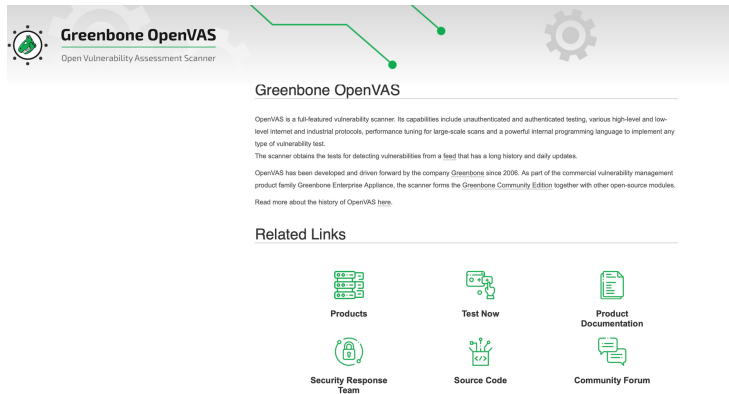
SkillUp

In collaboration with
IBM SkillsBuild

OPENVAS



Herramienta de escaneo de vulnerabilidades de código abierto con capacidad de integrarse con distintas plataformas de monitorización de sistemas y seguridad



<https://www.openvas.org>

- Escaneo de amplia variedad de servicios y redes, con capacidad de ajustar la amplitud y profundidad de la detección en los sistemas.
- Actualizaciones constantes
- Flexibilidad y escalabilidad: Admite una variedad de sistemas operativos IT y OT. Permite escanear grandes redes de forma eficiente.



Probar

Comprar

[Productos](#) / Nessus

Tenable Nessus®

La herramienta primordial en su conjunto de herramientas de ciberseguridad

Exponga y cierre las debilidades en su superficie de ataque en constante cambio con la solución de evaluación de vulnerabilidades más confiable de la industria.

Try Tenable Nessus for free

Comenzar

Al registrarse para esta licencia de prueba, Tenable podrá enviarle comunicaciones por correo electrónico sobre sus productos y servicios. Puede optar por no recibir estas comunicaciones en cualquier momento utilizando el enlace para darse de baja situado en el pie de página de los correos electrónicos que se le envían. También puede gestionar sus preferencias de correo electrónico de Tenable visitando la [página de gestión de suscripciones](#).

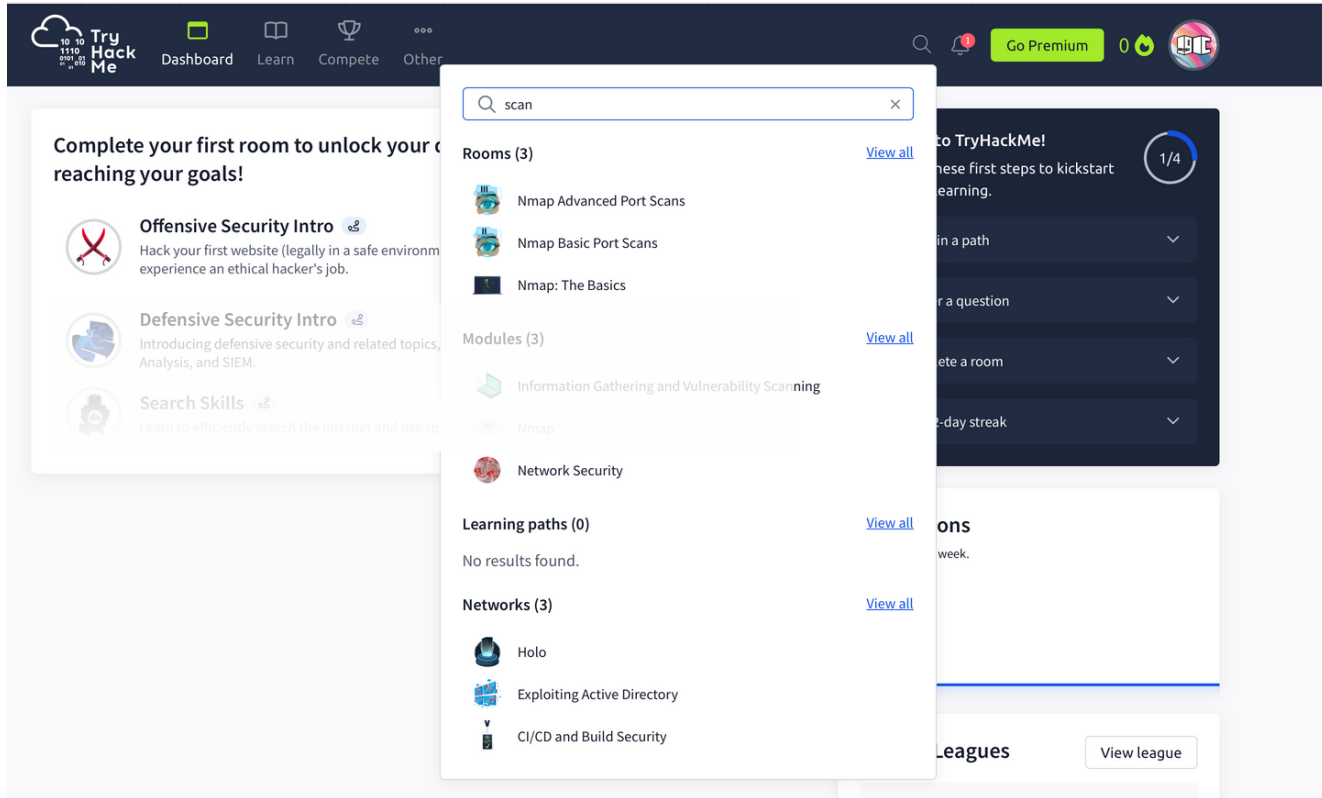
Tenable solo procesará sus datos personales de acuerdo con su [Política de privacidad](#).

<https://www.nessus.org>

SkillUp

In collaboration with
IBM SkillsBuild

Práctica en la nube



<https://tryhackme.com>

Existen plataformas en la nube que ofrecen laboratorios gratuitos donde ya tienes herramientas como Nmap, OpenVAS, Metasploit funcionando desde el navegador.

Ventajas: No necesitas instalar nada. Ofrecen entornos seguros y reales.

Enlace de retroalimentación

<https://survey.zohopublic.in/zs/UDUeV?lang=es>



Copyright Skill-Up technologies, All rights reserved . Submitted for evaluation purpose only as per existing NDA

SkillUp

In collaboration with
IBM **SkillsBuild**



¡Gracias!

Si tenés alguna pregunta adicional,
envianos un correo electrónico a:
ibmskillsbuild.eu@skillup.online

